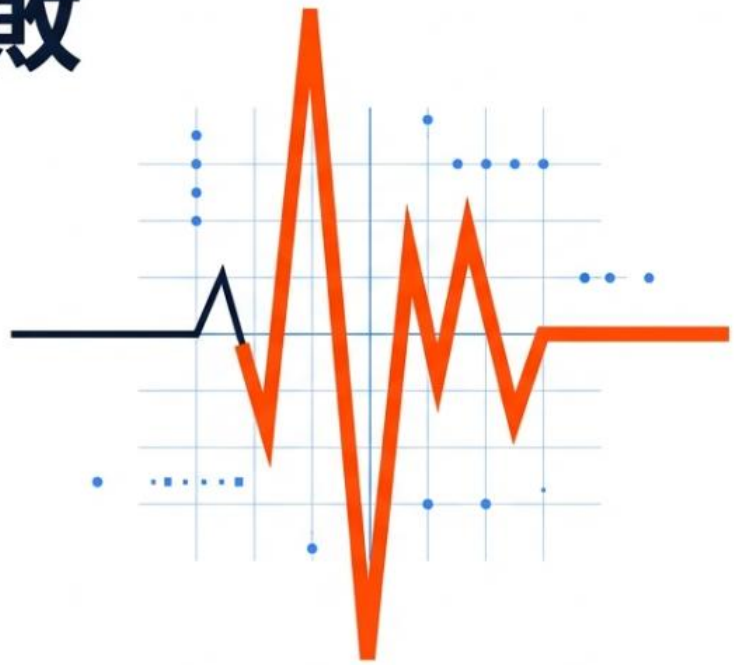
A09:2025 Security Logging & Alerting Failures

安全日誌與監控失敗

OWASP Top 10 A09:2025
解析與防禦指南

缺乏可見性是攻擊者的最佳掩護。

本指南將探討為何「偵測」與「回應」是防禦體系中最後且最關鍵的防線。



A09:2025 Security Logging & Alerting Failures

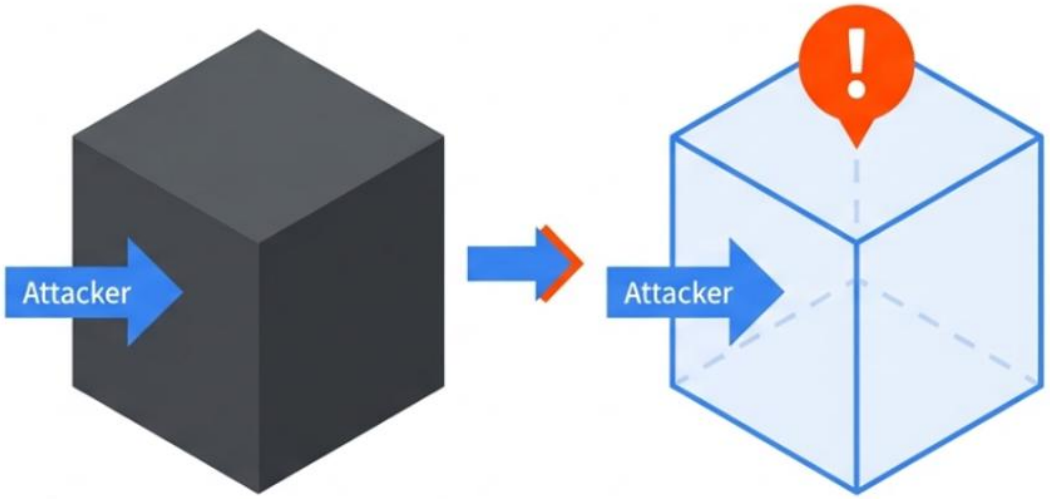
核心問題：若是看不見，就無法防禦

定義（Definition）
A09 不僅是關於日誌記錄（Logging），
更強調 監控（Monitoring）與警報
（Alerting）。
如果沒有這些機制，企業將陷入「安全盲區」。

關鍵行動（The 3 Imperatives）
- 偵測（Detect）：識別主動攻擊。
- 升級（Escalate）：將警報傳遞給正確的人員。
- 回應（Respond）：在損害擴大前採取行動。

數據背景（Data Context）
- OWASP 排名第 9
- 僅有 723 個 CVE 相關漏洞，難以透過自動化測試發現
- 平均加權影響極高：
  這不是技術漏洞，而是取證與應變能力的缺失

The Visibility Gap

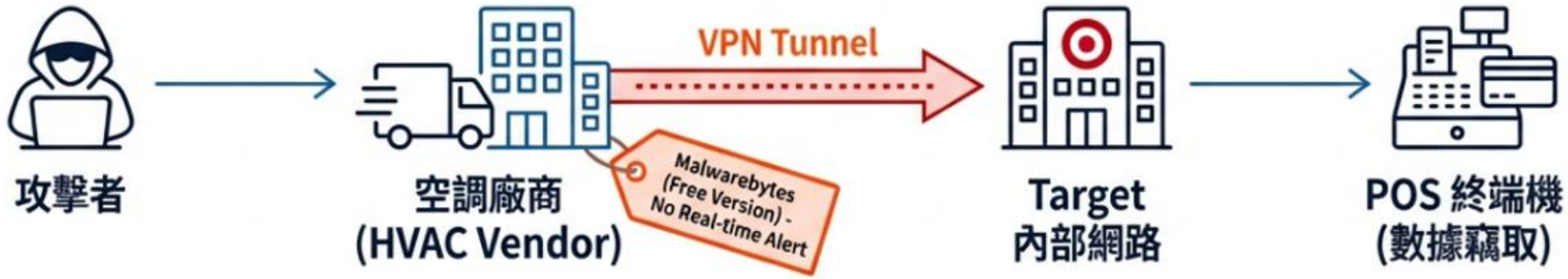


未受監控系統
（Unmonitored）

監控與警報
（Monitored）

A09:2025 Security Logging & Alerting Failures

案例分析一：即時監控失效（Target 百貨）



事件規模

2013 年史上最大規模之一的數據洩露，
導致 1,850 萬美元 的和解賠償。

攻擊路徑

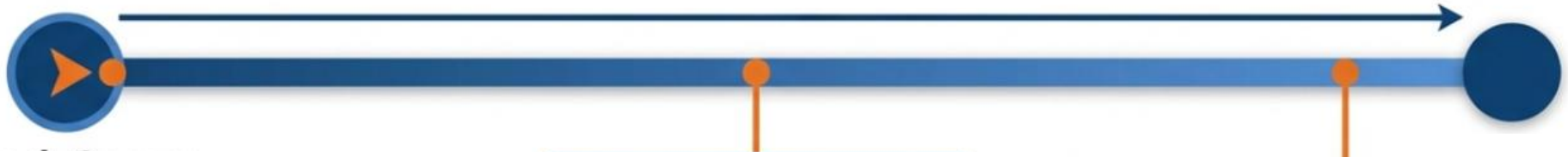
駭客並非直接攻擊 Target，
而是透過第三方空調廠商
（HVAC vendor）的
VPN 連線進行供應鏈攻擊。

關鍵失誤

該供應商安裝了防惡意軟體，
但使用的是免費版本。
免費版僅提供「按需掃描」，
缺乏「即時偵測」功能。
警報從未響起，導致駭客長驅直入。

A09:2025 Security Logging & Alerting Failures

案例分析二：偵測延遲與資料留存



Breach Occurs（入侵發生）

印度大型航空公司：
涉及 10 年份乘客資料。
雲端服務商在攻擊發生 數月後 才通知。

Discovery（發現）

兒童健保計畫：
攻擊者潛伏 7 年。
自 2013 年 起持續竊取 350 萬筆記錄。

時間差的代價（The Cost of Latency）若無足夠的歷史日誌（Retention）與主動監控，
企業可能在不知情的情況下長期洩露數據。攻擊發生與發現攻擊之間的時間差，是損害控制的關鍵。

A09:2025 Security Logging & Alerting Failures

診斷：為何監控體系會崩潰？

1. 技術層面的缺失（Technical Failures）

- **記錄不全：**
  僅記錄成功登入，忽略了失敗登入（Failed Logins）或高價值交易。
- **訊息模糊：**
  錯誤訊息不明確，無法提供上下文（Context）。
- **儲存風險：**
  日誌僅儲存在本地且未備份（No Backup），
  或未受防篡改保護（Tampering）。
- **編碼漏洞：**
  未處理日誌輸出的編碼，導致日誌注入攻擊（CWE-117)。

2. 流程與維運的缺失（Process Failures）

- **警報疲勞（Alert Fatigue）：**
  過多的誤報（False Positives）導致 SOC 團隊忽略真實警報。
- **缺乏升級劇本（No Playbook）：**
  初級分析師發現異常時，不知道該通知誰或何時升級（Escalation）。
- **工具使用不當：**
  依賴免費或功能不足的 DAST 工具，無法在滲透測試中觸發警報。

A09:2025 Security Logging & Alerting Failures

防禦策略 I：工程與開發規範

- **全面記錄（Log Everything Critical）**
  確保所有登入失敗、存取控制失敗及伺服器端輸入驗證失敗都被記錄。
- **上下文資訊（Context）**
  日誌必須回答「誰、做什麼、在哪裡、何時」，以便進行取證分析。
- **標準化格式（Format）**
  確保日誌格式易於被管理解決方案（如 ELK Stack）讀取與整合。
- **完整性保護（Integrity）**
  使用「僅可追加（Append-only）」的資料庫表，防止駭客刪除或篡改日誌。
- **安全編碼（Security）**
  正確編碼日誌資料（CWE-117）；避免寫入 PII 或密碼（CWE-532）。

A09:2025 Security Logging & Alerting Failures

防禦策略 II：維運與 DevSecOps

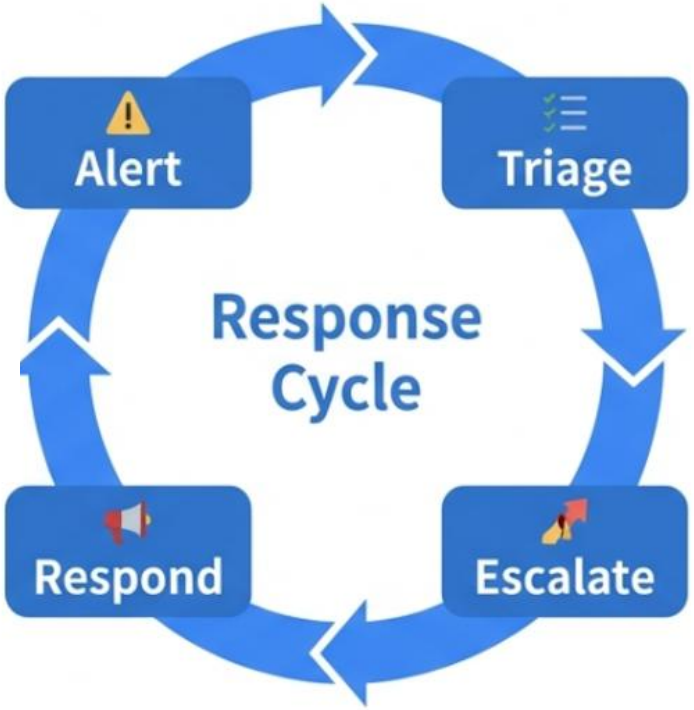
建立應變計畫（Incident Response）
採用 **NIST 800-61r2** 等標準，制定清晰的事件回應與復原計畫。

定義升級路徑
確保初級分析師有明確的指導方針（Playbooks），知道何時判定為「真實威脅」，以及何時必須向上層升級回報。

閾值調校（Thresholds）
設定合理的警報觸發門檻，降低誤報帶來的監控疲勞（Alert Fatigue）。

主動防禦：蜜罐代幣（Honeytokens）

在資料庫或應用中埋設「假數據」或「假帳號」，
這些數據在正常業務流程中不會被使用。
一旦被存取，即可高度判定攻擊行為發生，（零誤報）。



A09:2025 Security Logging & Alerting Failures

總結：建立可視化的防禦網

- 1. Fail Closed: 當系統出錯時，必須安全地失敗並留下紀錄。
- 2. 持續監控: 攻擊是持續的，監控也必須是 24/7 即時的。
- 3. 保留證據: 足夠長的日誌留存時間是事後取證與追責的基礎。

「你無法阻止每一次攻擊，但你必須偵測到每一次入侵。」
(You cannot prevent every attack, but you must detect every breach.)

A09:2025 Security Logging & Alerting Failures

總結：建立可視化的防禦網

1.Fail Closed：
當系統出錯時，必須安全地
失敗並留下紀錄。

2.持續監控：
攻擊是持續的，監控也必須
是 24/7 即時的。

3.保留證據：
足夠長的日誌留存時間，是事後取證與追責的基礎。

「你無法阻止每一次攻擊，但你必須偵測到每一次入侵。」
(You cannot prevent every attack, but you must detect every breach.)

A09:2025 Security Logging & Alerting Failures

OWASP TOP 10: 2025

A09:2025 – Security Logging & Monitoring Failures

程式碼常見錯誤案例與修正方案

A09:2025 Security Logging & Alerting Failures

錯誤示範：無效的日誌記錄（BAD PRACTICE）

```php
// BAD PRACTICE: Unstructured text to a local file
$error_msg = "Login failed for user: " . $username;
file_put_contents("/var/www/logs/error.txt", $error_msg, FILE_APPEND);
```

非結構化文字
難以進行自動化分析或匯入 SIEM 系統。

缺乏上下文
缺少來源 IP、User-Agent，或具體失敗原因。

"/var/www/logs/error.txt"

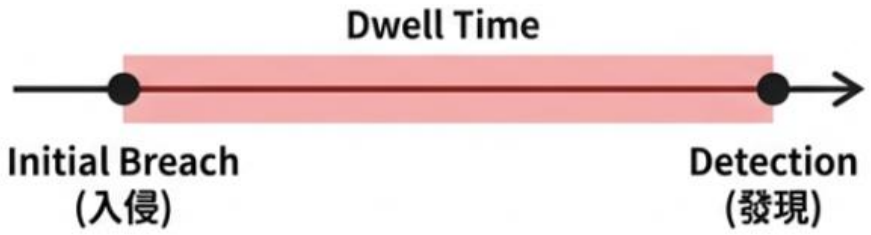
無告警機制
僅寫入檔案，沒有人會即時看到這條訊息。

本機儲存
若伺服器被駭，駭客可輕易刪除痕跡。

A09:2025 Security Logging & Alerting Failures

為何這是嚴重錯誤？

攻擊存活時間（Dwell Time）



未監控日誌
＝ 攻擊者可以在系統內長時間潛伏而不被發現。

失去可偵測性（Loss of Detectability）

當攻擊者進行 **暴力破解（Brute Force）** 時，
非結構化的程式碼只會產生大量雜亂文字。

管理員**無法設定**
「**一分鐘內失敗 5 次**」的自動告警規則，
因為系統**看不懂雜亂的文字日誌**。

> 「未記錄或未監控安全事件，等同於放棄事故可偵測性。」

A09:2025 Security Logging & Alerting Failures

符合標準的安全日誌（GOOD PRACTICE）

```php
// GOOD PRACTICE: Structured Logging (JSON) with Context
$log_payload = [
    "event"     => "auth.login.failed",
    "user"      => $username,
    "src_ip"    => $_SERVER['REMOTE_ADDR'],
    "timestamp" => time(),
    "outcome"   => "denied"
];
// Send to centralized logging system (e.g., ELK, Splunk)
logger->warning(json_encode($log_payload));
```

標準化事件名稱
使用 auth.login.failed（依據 OWASP Logging Cheat Sheet），
方便搜尋與過濾。

結構化資料（JSON）
包含完整欄位（IP、Timestamp、User），
機器可讀，可設定自動告警規則。

集中化管理
不存本機文字檔，而是發送到日誌伺服器，
防止竄改並支援即時監控。